EDICIÓN HOMENAJE · NO OFICIAL

CHECKLIST DE SEGURIDAD

Revisa tu app hecha con IA antes de lanzar

Ocho frentes que revisar con tu asistente de IA, en el orden que más protege tu dinero y los datos de tus usuarios.

Basado en una publicación en X de

Eli.js | Dev · @elijs_dev

https://x.com/elijs_dev/status/2113047772454883420

8 frentes | 4 reglas de revisión | Checklist de lanzamiento | Prompts propios

Kit gratuito · Regalado · No se vende · Síntesis original preparada por Gilbert Cruz · Octubre 2026

EL MÉTODO

Cuatro reglas y ocho frentes

Eli.js publicó en X ocho prompts para que la IA audite una app construida con IA antes de salir a producción. Su punto de partida: cuando le pides velocidad, la IA optimiza para que funcione, no para que sea segura. Este kit resume el método con palabras propias y añade prompts escritos de cero.

Regla 1 — **Dentro del proyecto**

Usa el asistente con acceso a tu código (editor o agente), no en un chat vacío: tiene que leer los archivos de verdad.

Regla 2 — **Un frente cada vez**

Primero el informe; luego lo revisas tú; después se arregla un hallazgo cada vez.

Regla 3 — **Archivo y línea**

Cada hallazgo debe decir dónde está. Sin ubicación, no cuenta.

Regla 4 — **Primero dinero y datos ajenos**

Secretos y reglas de la base de datos van antes que todo lo demás.

#	Frente	La pregunta clave
1	Secretos expuestos	¿Hay alguna clave o token en código que llega al navegador?
2	Reglas de la base de datos	Con la clave pública, ¿alguien podría leer o borrar datos de otros?
3	Propiedad de recursos (IDOR)	¿Cada ruta comprueba que el recurso pertenece a quien lo pide?
4	Validación en el servidor	¿Lo que envía el usuario se valida en el servidor y no solo en el formulario?
5	Abuso y costes	¿Login, registro, envíos y llamadas a APIs de IA tienen límites de uso?
6	Pagos y webhooks	¿El acceso de pago lo decide el servidor tras un webhook con firma verificada?
7	Autenticación y sesiones	¿Las sesiones caducan y cerrar sesión las invalida de verdad?
8	Revisión final	¿Qué arreglo hoy, qué esta semana y qué puede esperar?

Como advierte la autora: es una primera capa. No sustituye una auditoría profesional si manejas pagos a escala o datos sensibles.

CHECKLIST Y PLANTILLA

Checklist de lanzamiento

Repásala en cada versión que publiques, no solo la primera vez.

- [ ] Ninguna clave privada en el frontend ni en variables con prefijo público (NEXT_PUBLIC_, VITE_, EXPO_PUBLIC_...).
- [ ] El archivo .env está en .gitignore y las claves expuestas en el pasado se han rotado.
- [ ] Todas las tablas o colecciones tienen reglas de acceso activas y probadas con la clave pública.
- [ ] Cada ruta que devuelve o modifica un recurso comprueba el propietario usando la sesión, no un id enviado por el cliente.
- [ ] Toda entrada (formularios, parámetros, archivos) se valida en el servidor; los archivos, por tipo y tamaño.
- [ ] Login, registro, recuperación de contraseña, envíos y llamadas a IA tienen límite de uso.
- [ ] El estado de pago solo cambia tras un webhook con firma verificada; un webhook repetido no duplica nada.
- [ ] Sesiones con caducidad; cerrar sesión la invalida en el servidor.
- [ ] Los errores no muestran trazas ni consultas internas.
- [ ] Dependencias auditadas y cabeceras de seguridad revisadas.

Registro de hallazgos

Frente	Archivo:línea	Riesgo	Arreglo	Hecho

EJEMPLO PRÁCTICO

Una app de reservas pasa la revisión

EJEMPLO FICTICIO · DATOS INVENTADOS

«Turnos Fácil» es una app inventada de reservas para peluquerías, hecha con IA en un fin de semana. Así quedaría su registro tras los primeros frentes:

Frente	Hallazgo (ficticio)	Riesgo	Arreglo
Secretos	La clave de la API de IA está en una variable con prefijo público.	Alto	Moverla a una función de servidor y rotar la clave.
Base de datos	La tabla de citas no tiene reglas por fila.	Alto	Política: cada negocio ve solo sus citas.
IDOR	`/api/citas/:id` comprueba la sesión pero no el propietario.	Alto	Filtrar por el negocio de la sesión.
Pagos	El plan de pago se activa desde el cliente.	Alto	Activarlo solo tras webhook firmado e idempotente.
Abuso	El recordatorio por SMS no tiene límite.	Medio	Límite por usuario y por IP.

Qué hizo bien

- Pidió solo el informe antes de tocar código.
- Arregló primero lo que afectaba a dinero y a datos de otros.
- Guardó la checklist para repetirla en cada versión.

Ejemplo ficticio con datos inventados. No describe una app real.

CRÉDITO Y AVISO

Crédito y aviso

Eli.js | Dev · @elijs_dev

https://x.com/elijs_dev/status/2113047772454883420

Artículo publicado en X el 21 de octubre de 2026 (UTC): «8 prompts para validar la seguridad de tu app hecha con IA antes de lanzar». Los ocho frentes, el orden de prioridad y las reglas de uso son suyos.

Este kit es un **homenaje no oficial**. Resume con palabras propias un artículo público y añade una checklist, un registro, un ejemplo ficticio y prompts redactados de cero por Gilbert Cruz; los prompts originales de la autora no se reproducen. No se ha copiado texto, imágenes ni marca, y la autora no lo ha revisado ni respaldado.

- Gratis: se regala, no se vende.
- Sin relación con la autora.
- No es asesoramiento de seguridad profesional.
- Si la autora quiere cambios o prefiere que no exista, se edita o se retira.